

APP.4.5 Key-Value-Datenbanken

1 Beschreibung

1.1 Einleitung

Key-Value-Datenbanken, oft auch als Key-Value-Stores bezeichnet, sind eine fundamentale Kategorie nicht-relationaler Datenbanken. Systeme wie Redis, Memcached oder RocksDB speichern Daten in einfachen Schlüssel-Werte-Paaren und sind für extrem hohe Lese- und Schreibgeschwindigkeiten optimiert. Häufig werden sie als In-Memory-Datenbanken betrieben, um als hochperformanter Cache, Session-Store oder für Echtzeitanalysen zu dienen.

Ihre Architektur, die auf maximale Performance und geringe Latenz ausgelegt ist, führt häufig zu Standardkonfigurationen, die aus Sicherheitssicht problematisch sein können. Solche Systeme bieten standardmäßig oft keine oder nur rudimentäre Authentifizierungsmechanismen, sind im Netzwerk unverschlüsselt erreichbar und verfügen über mächtige Administrationsbefehle, die nicht ausreichend geschützt sind. Diese Eigenschaften stellen spezifische Anforderungen an die Absicherung, die sich von denen relationaler Datenbanksysteme unterscheiden.

1.2 Zielsetzung

Dieser Baustein zeigt einen systematischen Weg auf, um Key-Value-Datenbanken sicher zu konfigurieren und zu betreiben. Ziel ist es, die Vertraulichkeit, Integrität und Verfügbarkeit der gespeicherten Daten zu gewährleisten. Dies umfasst die Absicherung des Netzwerkzugriffs, die Etablierung von Authentifizierungs- und Autorisierungsmechanismen, die Härtung der Konfiguration und die sichere Anbindung an die zugehörigen Anwendungen.

1.3 Abgrenzung und Modellierung

Der Baustein APP.4.5 ist auf alle eingesetzten Key-Value-Datenbanken anzuwenden. Er ist eine Ergänzung zum Baustein APP.4.3 *Relationale Datenbanksysteme* und deckt die spezifischen Anforderungen nicht-relationaler Key-Value-Stores ab.

Grundlegende Anforderungen an die Absicherung des darunterliegenden Betriebssystems sind nicht Teil dieses Bausteins, sondern werden in SYS.1.1 *Allgemeiner Server* behandelt. Vorgaben an die sichere Entwicklung von Anwendungen, die diese Datenbanken nutzen, finden sich in CON.8 *Software-Entwicklung (auftragnehmende Seite)* sowie APP.7 *Entwicklung von Individualsoftware (auftraggebende Seite)*. Aspekte der Netzseparierung sind in NET.1.1 *Netzarchitektur und -design* beschrieben.

2 Gefährdungslage

Für Key-Value-Datenbanken sind folgende spezifische Gefährdungen von besonderer

Bedeutung:

Unautorisierter Zugriff auf sensible Daten im Speicher

Da viele Key-Value-Datenbanken standardmäßig ohne Authentifizierung betrieben werden und im Netzwerk lauschen, können Angreifer mit reinem Netzwerkzugriff auf den gesamten Datenbestand zugreifen. Dadurch können sensible Informationen wie Session-Token, personenbezogene Daten oder Konfigurationsparameter ausgelesen, manipuliert oder gelöscht werden.

Ausnutzung unsicherer Standardkonfigurationen

Key-Value-Datenbanken sind oft auf einfache Inbetriebnahme und maximale Leistung optimiert. Häufige Schwachstellen in der Standardkonfiguration sind das Binden an alle Netzwerkschnittstellen, das Fehlen einer Passwortabfrage oder die Aktivierung von potenziell gefährlichen Debugging-Funktionen. Werden diese Einstellungen nicht gehärtet, sind die Systeme offen für Kompromittierungen.

Manipulation von zwischengespeicherten Daten (Cache Poisoning)

Gelingt es einem Angreifer, Daten im Cache zu manipulieren, kann dies weitreichende Folgen für die angebundene Anwendung haben. Beispielsweise könnten durch die Manipulation von zwischengespeicherten Benutzerrechten unautorisierte Zugriffe ermöglicht oder durch das Einschleusen von Schadcode in gecachte Webseiten-Fragmente Cross-Site-Scripting-Angriffe durchgeführt werden.

Denial-of-Service durch Ressourcenerschöpfung

Da Key-Value-Stores häufig primär im Arbeitsspeicher (RAM) operieren, sind sie anfällig für Angriffe, die auf eine Erschöpfung der Speicherressourcen abzielen. Ein Angreifer könnte unauthentifiziert massenhaft Daten in die Datenbank schreiben, bis der Arbeitsspeicher voll ist und das System oder die davon abhängige Anwendung ausfällt.

Unsichere Kommunikation im Cluster-Betrieb

In einem Cluster-Setup kommunizieren die einzelnen Knoten untereinander, um Daten zu replizieren oder den Cluster-Status abzugleichen. Erfolgt diese Kommunikation unverschlüsselt, können Angreifer im selben Netzwerksegment Daten abhören oder manipulieren. Wird ein Knoten auf diesem Weg übernommen, kann dies zur Kompromittierung des gesamten Clusters führen.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins APP.4.5 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

APP.4.5.A1 Absicherung des Netzwerkzugriffs (B)

Der Netzwerkzugriff auf die Key-Value-Datenbank MUSS auf das zwingend erforderliche Minimum beschränkt werden. Die Datenbank DARF NICHT an alle verfügbaren Netzwerkschnittstellen gebunden werden. Sie MUSS ausschließlich an vertrauenswürdige Schnittstellen (z. B. lokales Loopback-Interface bei rein lokaler Nutzung) gebunden werden. Zusätzlich MUSS der Zugriff auf Port-Ebene durch Paketfilter oder Firewalls strikt auf die Systeme beschränkt werden, die technisch zwingend auf die Datenbank zugreifen müssen.

APP.4.5.A2 Aktivierung einer grundlegenden Authentifizierung (B)

Sofern von der Datenbank nativ unterstützt, MUSS ein Authentifizierungsmechanismus für eingehende Verbindungen aktiviert werden. Es MUSS mindestens ein sicheres Passwort für den Zugriff konfiguriert werden, um anonyme Vollzugriffe zu verhindern.

APP.4.5.A3 Härtung der Konfiguration (B)

Potenziell gefährliche Befehle, die administrative Eingriffe erlauben (z. B. das Auslesen der gesamten Serverkonfiguration oder das sofortige Löschen aller Datenbestände), MÜSSEN deaktiviert oder durch Umbenennung vor unbefugter Nutzung geschützt werden. Unsichere Standardeinstellungen der jeweiligen Software MÜSSEN vor Produktivsetzung identifiziert und korrigiert werden.

APP.4.5.A4 Ausführung mit dediziertem Benutzerkonto (B)

Die Key-Value-Datenbank MUSS auf dem Betriebssystem unter einem eigenen, dedizierten Benutzerkonto mit minimalen Rechten betrieben werden. Der Betrieb unter einem administrativen Konto (z. B. root) DARF NICHT erfolgen.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

APP.4.5.A5 Verschlüsselung der Datenübertragung (S)

Die gesamte Netzwerkkommunikation zwischen den angebundenen Anwendungen und der Key-Value-Datenbank sowie die Kommunikation zwischen den Knoten in einem Cluster-Verbund SOLLTE mittels TLS verschlüsselt werden.

APP.4.5.A6 Erstellung eines differenzierten Rechtekonzepts (S) [Entwickler]

Sofern von der Datenbank unterstützt (z. B. über Access Control Lists), SOLLTE ein differenziertes Rechtekonzept umgesetzt werden. Für jede zugreifende Anwendung SOLLTE ein eigener Datenbankbenutzer angelegt werden. Diesem SOLLTEN strikt nur die minimal erforderlichen Berechtigungen für zwingend benötigte Befehle und Schlüsselmuster (Key-Spaces) zugewiesen werden.

APP.4.5.A7 Sichere Konfiguration der Datenpersistenz (S)

Falls die Key-Value-Datenbank Daten auf Festplatten persistiert (z. B. für Backups, Snapshots oder nach Neustarts), SOLLTE sichergestellt werden, dass die erzeugten Dateien mit restriktiven Dateiberechtigungen versehen sind. Der Speicherort im Dateisystem SOLLTE so gewählt und abgesichert werden, dass unbefugte Zugriffe verhindert werden.

APP.4.5.A8 Regelmäßige Protokollierung und Überwachung (S)

Verbindungsversuche sowie administrative oder kritische Befehle SOLLTEN protokolliert und an ein zentrales Log-Management-System übergeben werden. Die Protokolle SOLLTEN regelmäßig auf verdächtige Aktivitäten, wie massenhaft fehlgeschlagene Authentifizierungen oder die versuchte Nutzung blockierter Befehle, ausgewertet werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

APP.4.5.A9 Absicherung der Cluster-Kommunikation mit mTLS (H)

In Cluster-Umgebungen SOLLTE die gesamte Kommunikation zwischen den Knoten (Replikation, Statusabgleich) durch gegenseitige TLS-Authentifizierung (Mutual TLS / mTLS) abgesichert werden. Jeder Knoten SOLLTE die Identität der anderen Knoten anhand von Zertifikaten zwingend überprüfen. (C, I)

APP.4.5.A10 Einsatz in einer isolierten und gehärteten Laufzeitumgebung (H)

Die Key-Value-Datenbank SOLLTE in einer dedizierten, stark gehärteten Laufzeitumgebung betrieben werden, beispielsweise in einem minimalen, speziell gebauten Container-Image

(Distroless). Der Netzwerkzugriff und die Systemaufrufe (Syscalls) SOLLTEN durch technische Maßnahmen des Betriebssystems (z. B. AppArmor, seccomp) auf das absolute Minimum beschränkt werden. (C, I, A)

APP.4.5.A11 Verschlüsselung von persistenten Daten (Encryption at Rest) (H)

Wenn hochsensible Daten verarbeitet und persistent gespeichert werden, SOLLTEN die Daten auf dem Speichermedium verschlüsselt abgelegt werden. Dies SOLLTE entweder durch transparente Funktionen des Betriebssystems (Festplattenverschlüsselung) oder durch datenbankeigene Mechanismen erfolgen. (C, I)

APP.4.5.A12 Regelmäßige Konfigurations- und Schwachstellen-Audits (H)

Die Konfiguration der Key-Value-Datenbank sowie die Version der eingesetzten Software SOLLTEN regelmäßig automatisiert auf bekannte Schwachstellen (CVEs) und Abweichungen von einer definierten, sicheren Basiskonfiguration (Hardening-Baseline) überprüft werden. (C, I, A)

4 Weiterführende Informationen

4.1 Wissenswertes

Das *Open Worldwide Application Security Project (OWASP)* bietet in seinen Leitfäden grundlegende Best Practices zur Absicherung von Backend-Komponenten und Caching-Systemen.

Herstellerspezifische Härtingsleitfäden, wie das *Redis Security Management* oder die *Memcached Security Architecture*, sollten bei der Umsetzung als Referenz für die jeweilige Zieltechnologie herangezogen werden.

Kreuzreferenztafel zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein APP.4.5 von Bedeutung:

- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.15 Abhören
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.27 Ressourcenmangel
- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.40 Verhinderung von Diensten (Denial of Service)

Anforderung	G 0.14	G 0.15	G 0.18	G 0.22	G 0.23	G 0.27	G 0.31	G 0.40
APP.4.5.A1 (B)	X				X			
APP.4.5.A2 (B)	X			X	X			
APP.4.5.A3 (B)			X				X	
APP.4.5.A4 (B)					X		X	
APP.4.5.A5 (S)	X	X		X				
APP.4.5.A6 (S)	X			X			X	
APP.4.5.A7 (S)	X			X	X			
APP.4.5.A8 (S)					X		X	
APP.4.5.A9 (H)		X		X	X			
APP.4.5.A10 (H)					X	X		X

APP.4. 5.A11 (H)	X			X				
APP.4. 5.A12 (H)			X				X	